

E-commerce

business. technology. society.

Sixth Edition

Chapter 5

Online Security and Payment Systems

The E-commerce Security Environment

- Overall size and losses of cybercrime unclear
  - Reporting issues
- survey: 49% respondent firms detected security breach in last year
  - Of those that shared numbers, average loss $288,000
- Underground economy marketplace
  - Stolen information stored on underground economy servers

Types of Attacks Against Computer Systems (Cybercrime)

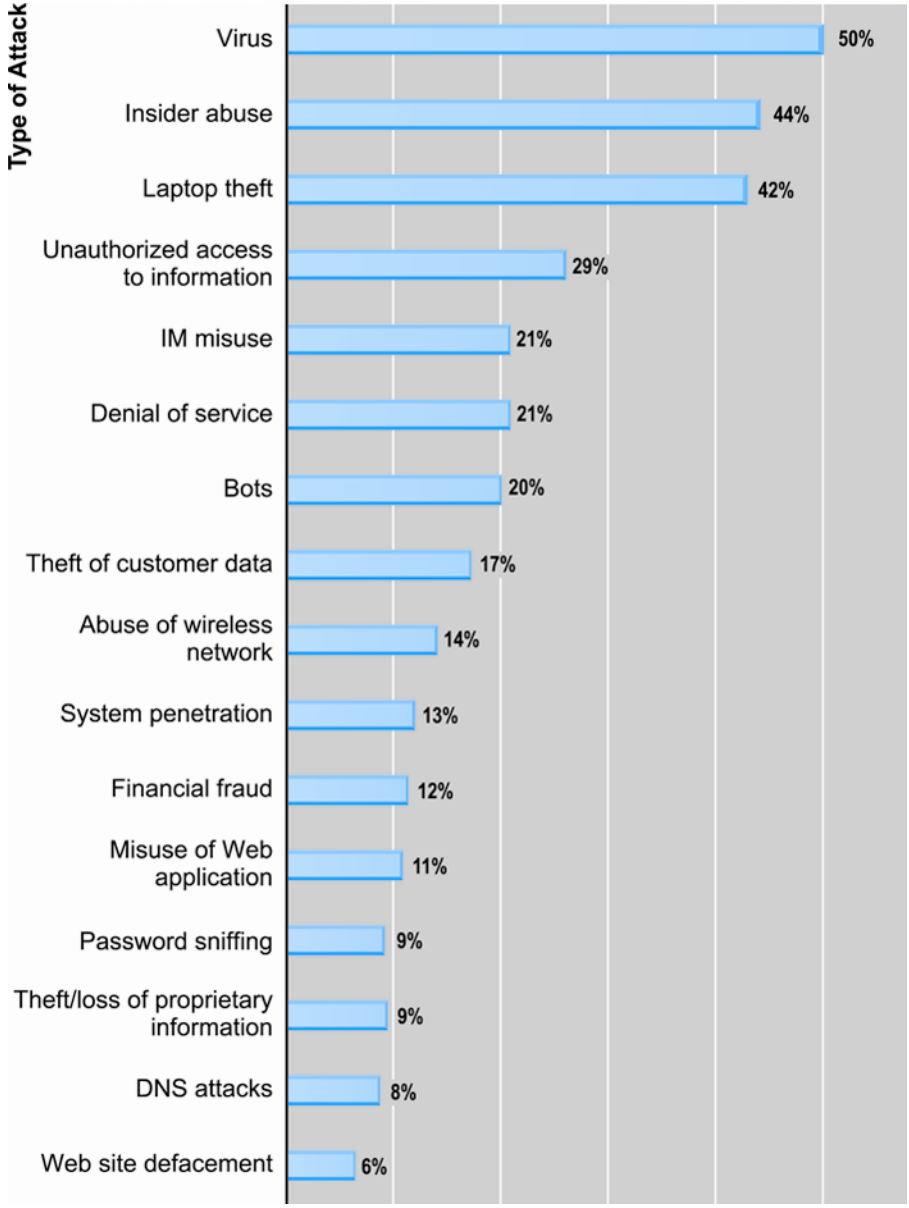


Figure 5.1, Page 267

Source: Based on data from Computer Security Institute, 2009.

What Is Good E-commerce Security?

- To achieve highest degree of security
  - New technologies
  - Organizational policies and procedures
  - Industry standards and government laws
- Other factors
  - Time value of money
  - Cost of security vs. potential loss
  - Security often breaks at weakest link

The E-commerce Security Environment

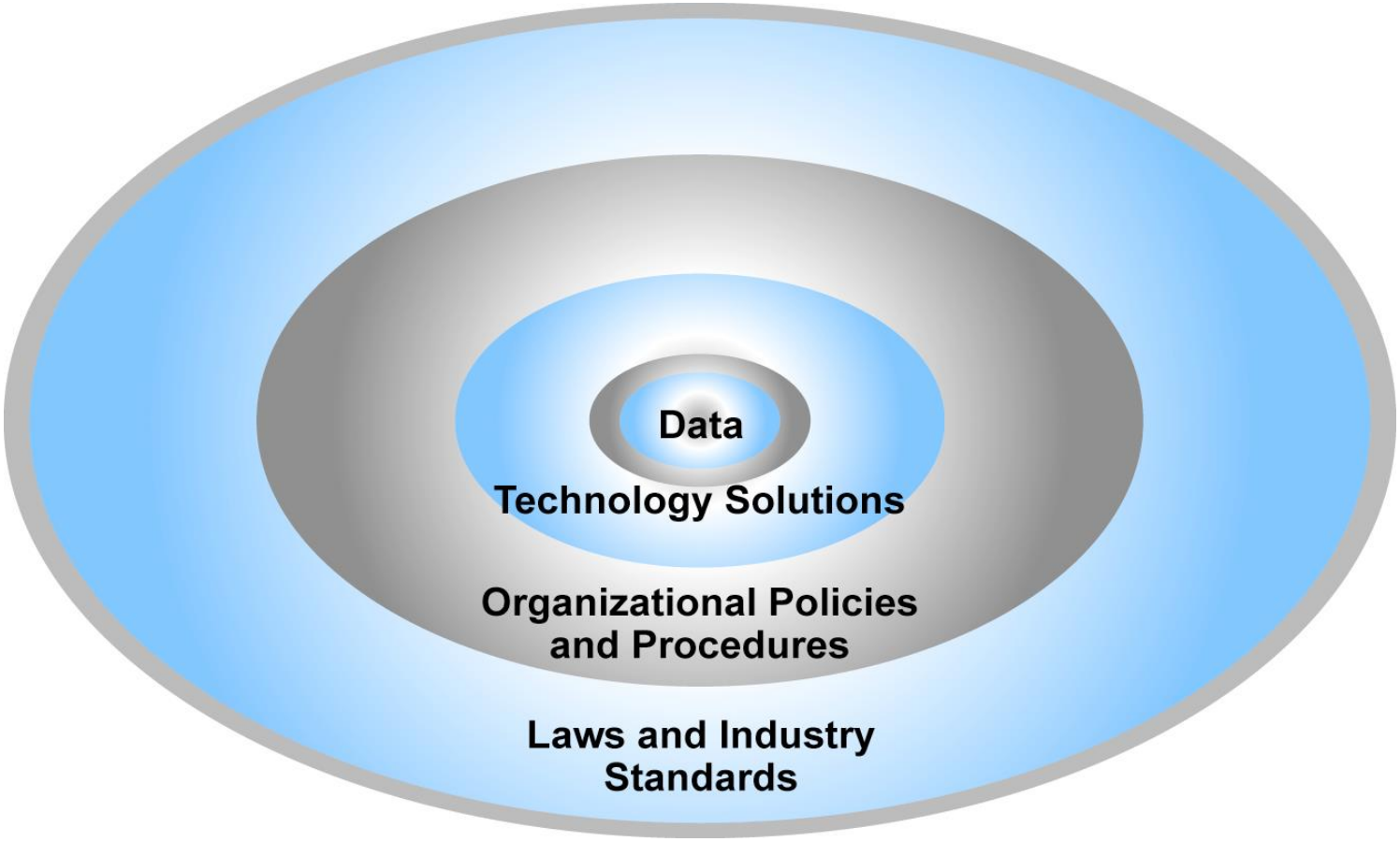


Figure 5.2, Page 270

TABLE 5.2	CUSTOMER AND MERCHANT PERSPECTIVES ON THE DIFFERENT DIMENSIONS OF E-COMMERCE SECURITY	
DIMENSIONS	CUSTOMER'S PERSPECTIVE	MERCHANT'S PERSPECTIVE
Integrity	Has information I transmit or receive been altered?	Has data on the site been altered without authorization? Is data being received from customers valid?
Nonrepudiation	Can a party to an action with me later deny taking the action?	Can a customer deny ordering products?
Authenticity	Who am I dealing with? How can I be assured that the person or entity is who they claim to be?	What is the real identity of the customer?
Confidentiality	Can someone other than the intended recipient read my messages?	Are messages or confidential data accessible to anyone other than those authorized to view them?
Privacy	Can I control the use of information about myself transmitted to an e-commerce merchant?	What use, if any, can be made of personal data collected as part of an e-commerce transaction? Is the personal information of customers being used in an unauthorized manner?
Availability	Can I get access to the site?	Is the site operational?

Table 5.2, Page 271

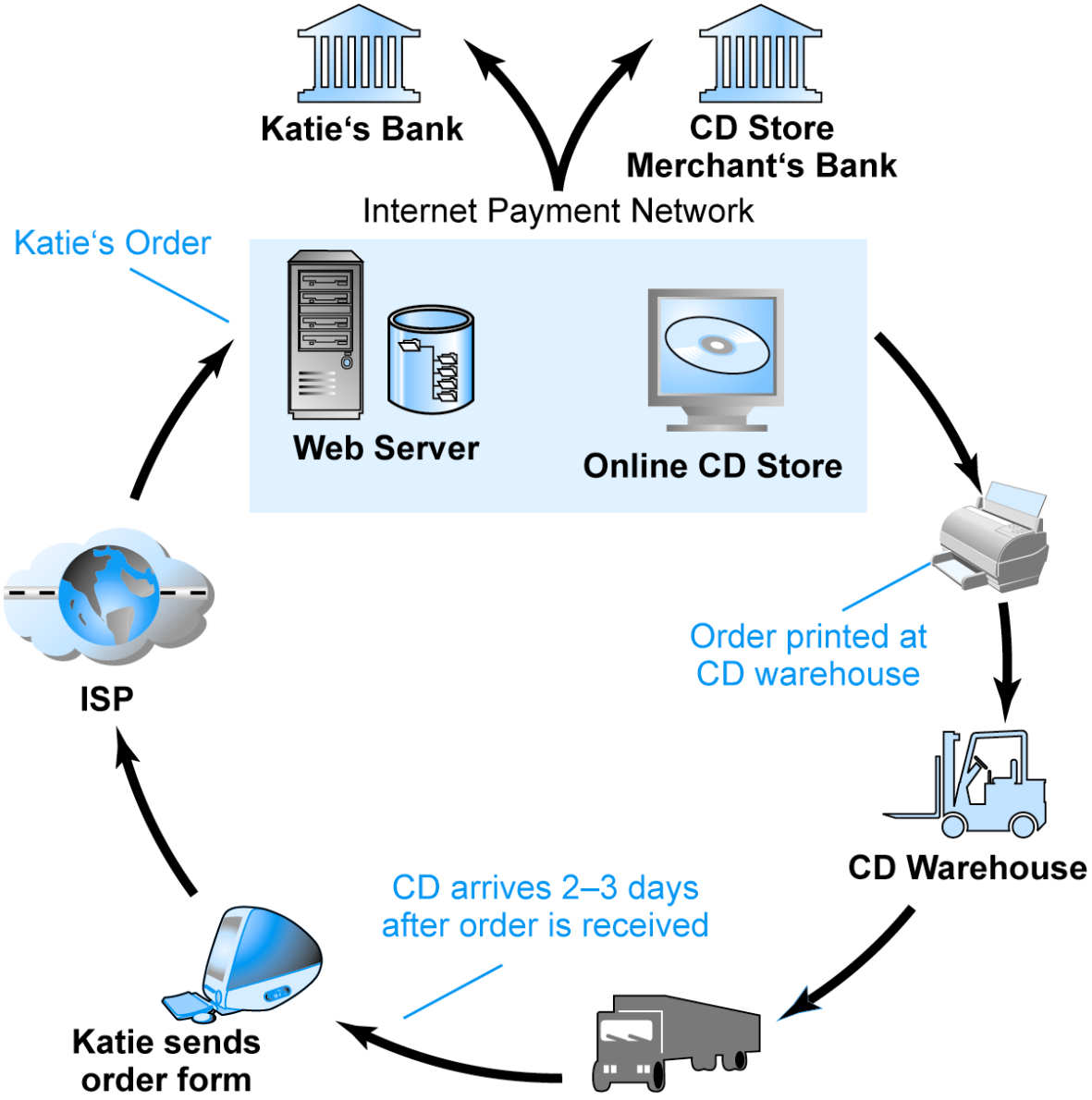
The Tension Between Security and Other Values

- Security vs. ease of use
  - The more security measures added, the more difficult a site is to use, and the slower it becomes
- Security vs. desire of individuals to act anonymously
  - Use of technology by criminals to plan crimes or threaten nation-state

Security Threats in the E-commerce Environment

- Three key points of vulnerability:
  1. Client
  2. Server
  3. Communications pipeline

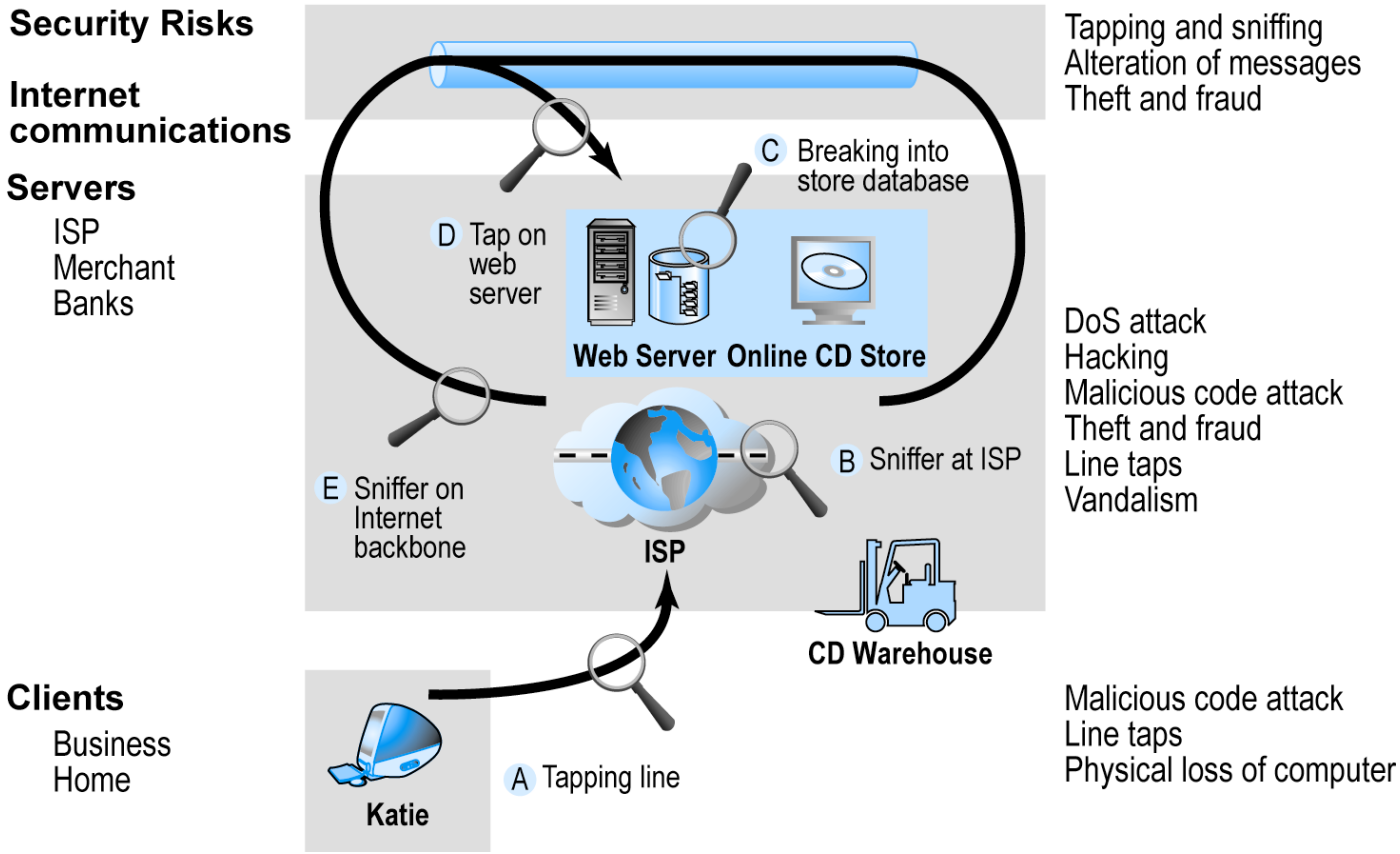
A Typical E-commerce Transaction



SOURCE: Boncella, 2000.

Figure 5.3, Page 273

Vulnerable Points in an E-commerce Environment



SOURCE: Boncella, 2000.

Figure 5.4, Page 274

Most Common Security Threats in the E-commerce Environment

- Malicious code **(To Be)**
  - Viruses
  - Worms
  - Trojan horses
  - Bots, botnets
- Unwanted programs **(To Be)**
  - Browser parasites
  - Adware
  - Spyware

Most Common Security Threats

- Phishing
  - Deceptive online attempt to obtain confidential information
  - Social engineering, e-mail scams, spoofing legitimate Web sites
  - Use information to commit fraudulent acts (access checking accounts), steal identity
- Hacking and cybervandalism
  - Hackers vs. crackers
  - Cybervandalism: intentionally disrupting, defacing, destroying Web site
  - Types of hackers: white hats, black hats, grey hats **(To Be)**

Most Common Security Threats

- Credit card fraud/theft
  - Fear of stolen credit card information decreases online purchases
  - Hackers target merchant servers; use data to establish credit under false identity
  - Online companies at higher risk than offline
- Spoofing: misrepresenting self by using fake e-mail address
- Pharming: spoofing a Web site
  - Redirecting a Web link to a new, fake Web site
- Spam/junk Web sites
- Splogs

Most Common Security Threats

- Denial of service (DoS) attack
  - Hackers flood site with useless traffic to overwhelm network
- Distributed denial of service (DDoS) attack
  - Hackers use multiple computers to attack target network
- Sniffing
  - Eavesdropping program that monitors information traveling over a network
- Insider jobs
  - Single largest financial threat
- Poorly designed server and client software

Technology Solutions

- Protecting Internet communications (encryption)
- Securing channels of communication (SSL, S-HTTP, VPNs) **(To be)**
- Protecting networks (firewalls)
- Protecting servers and clients

Tools Available to Achieve Site Security

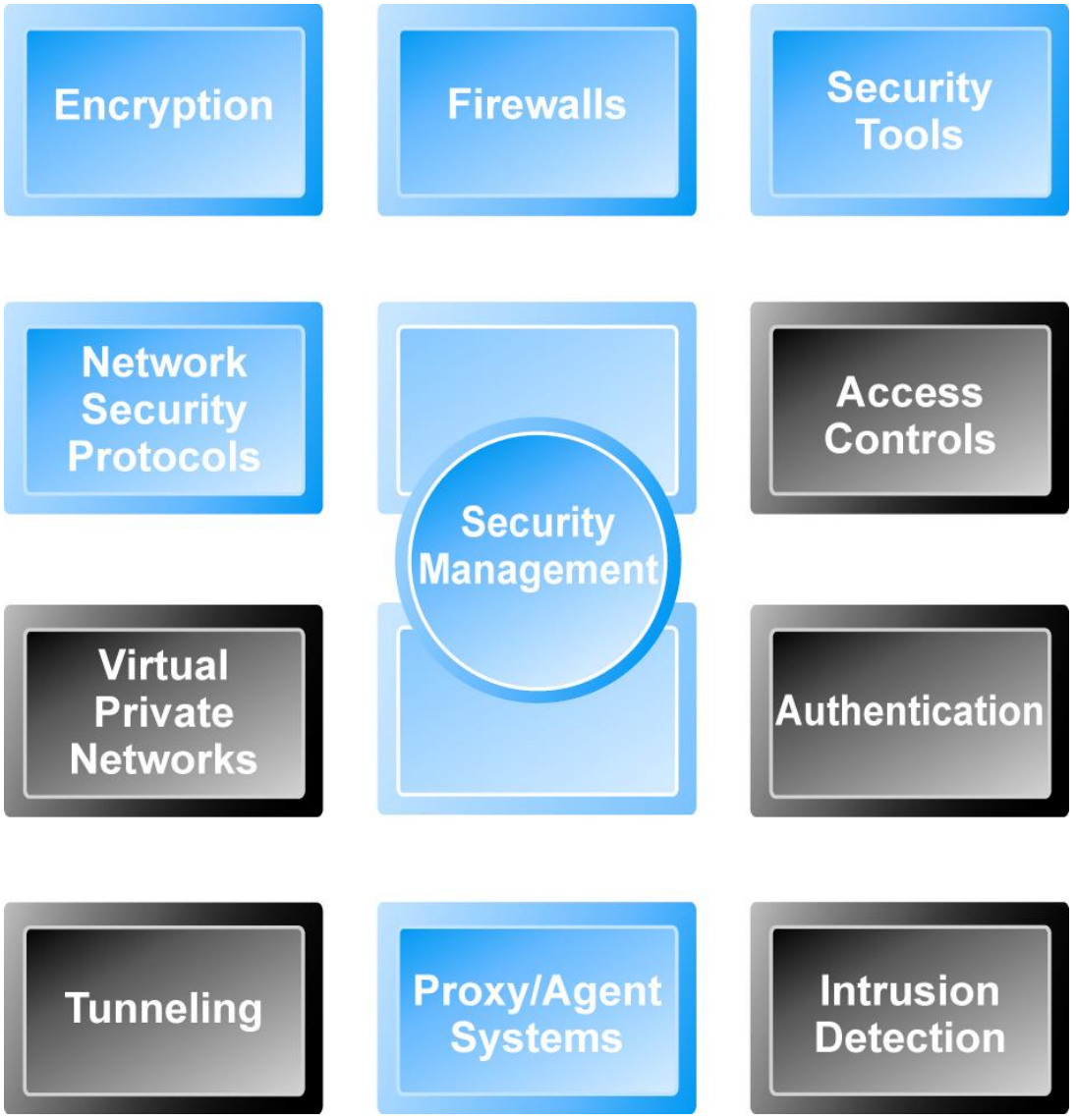


Figure 5.7, Page 287

Encryption

- Encryption
  - Transforms data into cipher text readable only by sender and receiver
  - Secures stored information and information transmission
  - Provides 4 of 6 key dimensions of e-commerce security:
    1. Message integrity
    2. Nonrepudiation
    3. Authentication
    4. Confidentiality

Symmetric Key Encryption

- Sender and receiver use same digital key to encrypt and decrypt message
- Requires different set of keys for each transaction
- Strength of encryption
  - Length of binary key used to encrypt data
- Advanced Encryption Standard (AES)
  - Most widely used symmetric key encryption
  - Uses 128-, 192-, and 256-bit encryption keys
- Other standards use keys with up to 2,048 bits

Public Key Encryption

- Uses two mathematically related digital keys
  1. Public key (widely disseminated)
  2. Private key (kept secret by owner)
- Both keys used to encrypt and decrypt message
- Once key used to encrypt message, same key cannot be used to decrypt message
- Sender uses recipient's public key to encrypt message; recipient uses his/her private key to decrypt it

Public Key Cryptography—A Simple Case

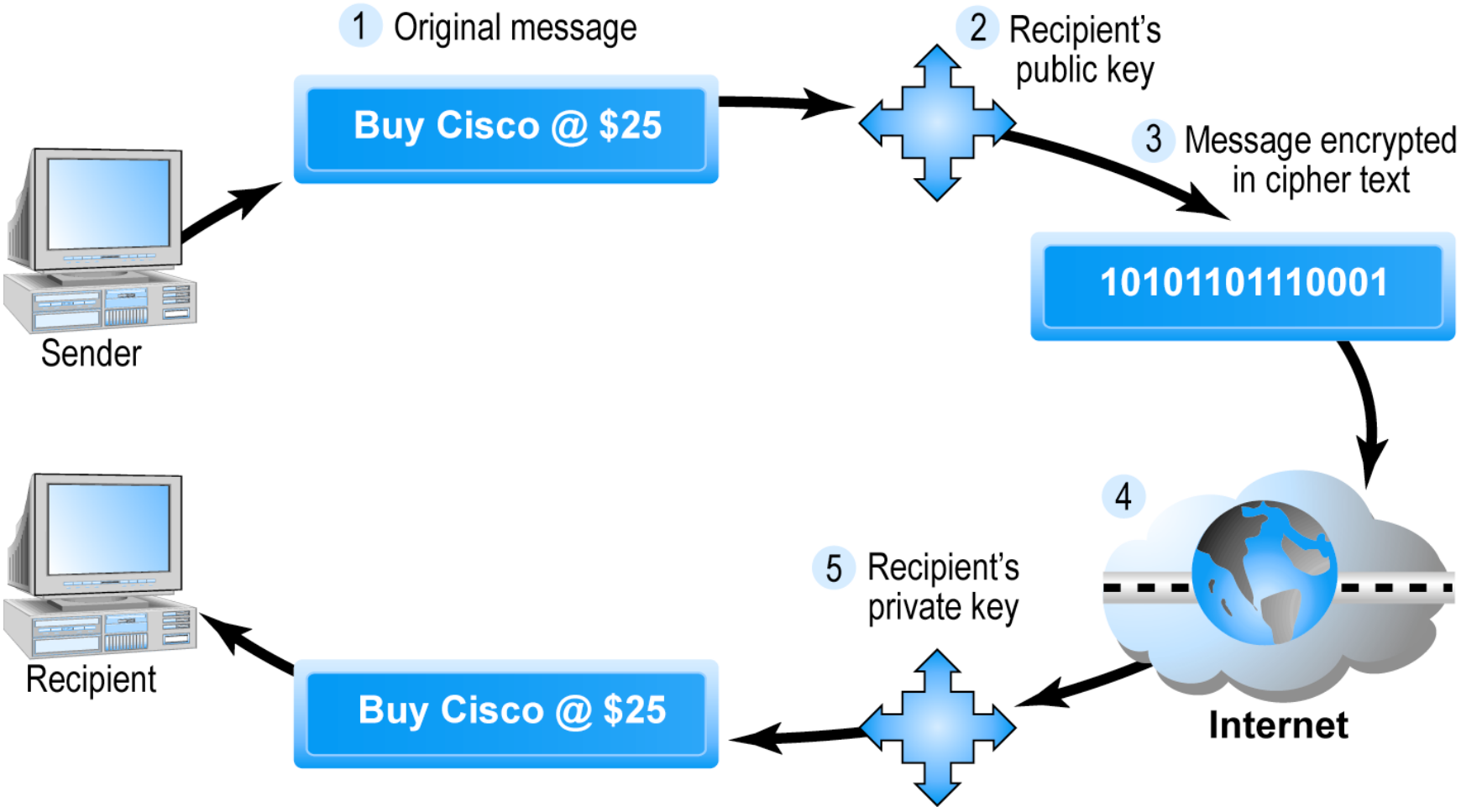


Figure 5.8, Page 290

Public Key Encryption Using Digital Signatures and Hash Digests

- Hash function:
  - Mathematical algorithm that produces fixed-length number called message or hash digest
- Hash digest of message sent to recipient along with message to verify integrity
- Hash digest and message encrypted with recipient's public key
- Entire cipher text then encrypted with recipient's private key—creating digital signature—for authenticity, nonrepudiation

Public Key Cryptography with Digital Signatures

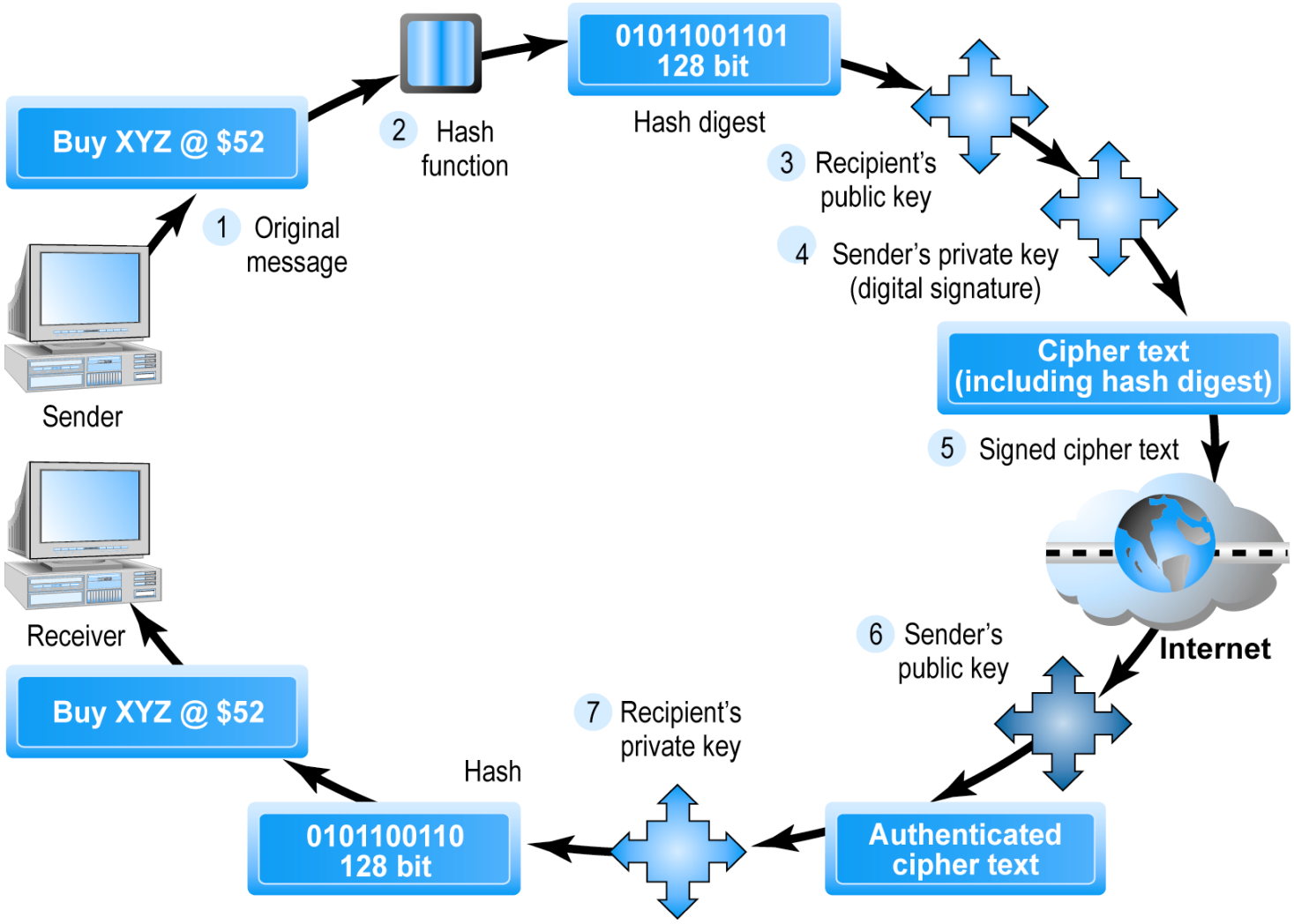


Figure 5.9, Page 291

Digital Envelopes

- Addresses weaknesses of:
  - Public key encryption
    - Computationally slow, decreased transmission speed, increased processing time
  - Symmetric key encryption
    - Insecure transmission lines
- Uses symmetric key encryption to encrypt document
- Uses public key encryption to encrypt and send symmetric key

Creating a Digital Envelope

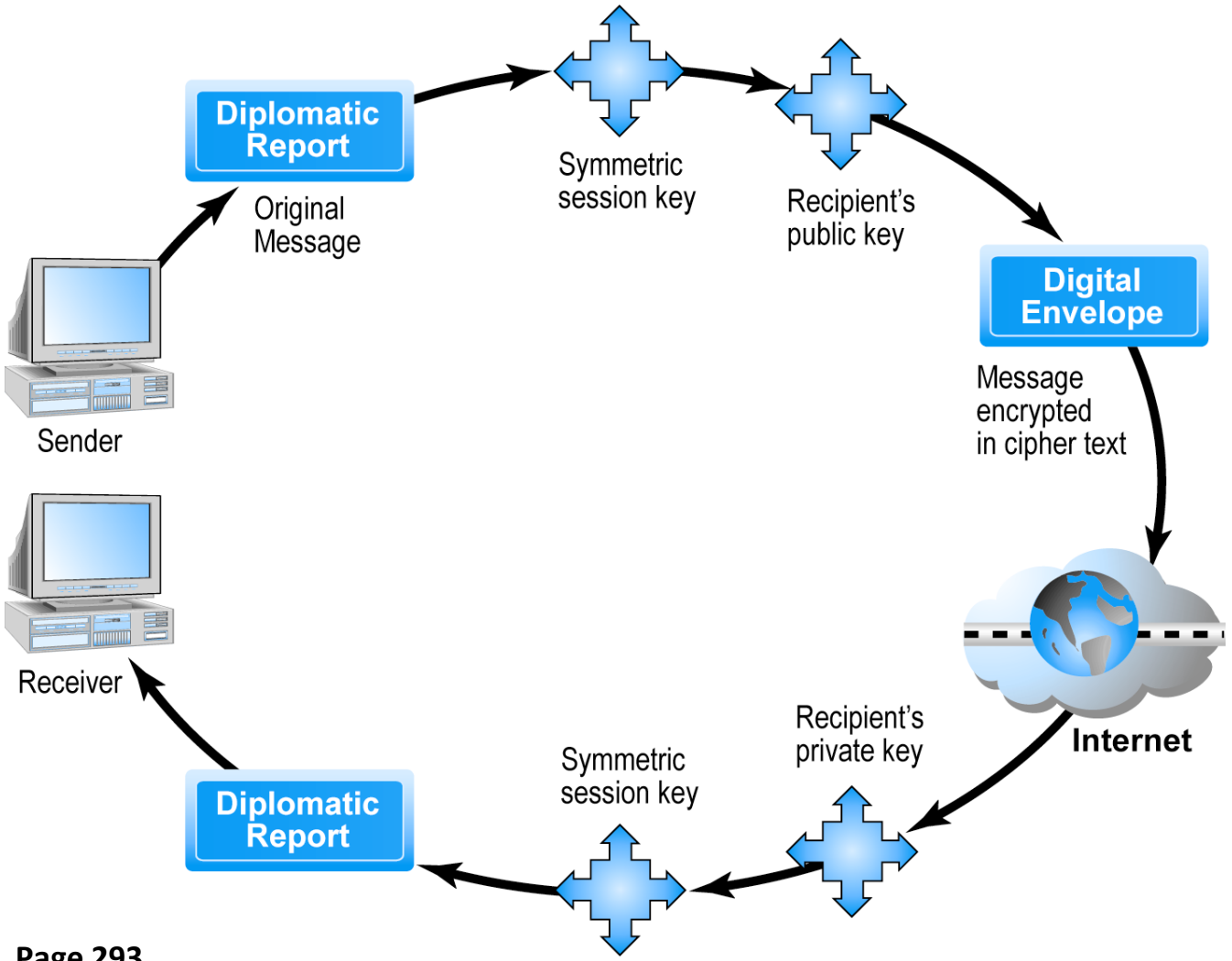


Figure 5.10, Page 293

Securing Channels of Communication

- Secure Sockets Layer (SSL):
  - Establishes a secure, negotiated client-server session in which URL of requested document, along with contents, is encrypted
- S-HTTP:
  - Provides a secure message-oriented communications protocol designed for use in conjunction with HTTP
- Virtual Private Network (VPN):
  - Allows remote users to securely access internal network via the Internet, using Point-to-Point Tunneling Protocol (PPTP)

Protecting Networks

- Firewall
  - Hardware or software that filters packets
  - Prevents some packets from entering the network based on security policy
  - Two main methods:
    1. Packet filters
    2. Application gateways
- Proxy servers (proxies)
  - Software servers that handle all communications originating from or being sent to the Internet

Firewalls and Proxy Servers

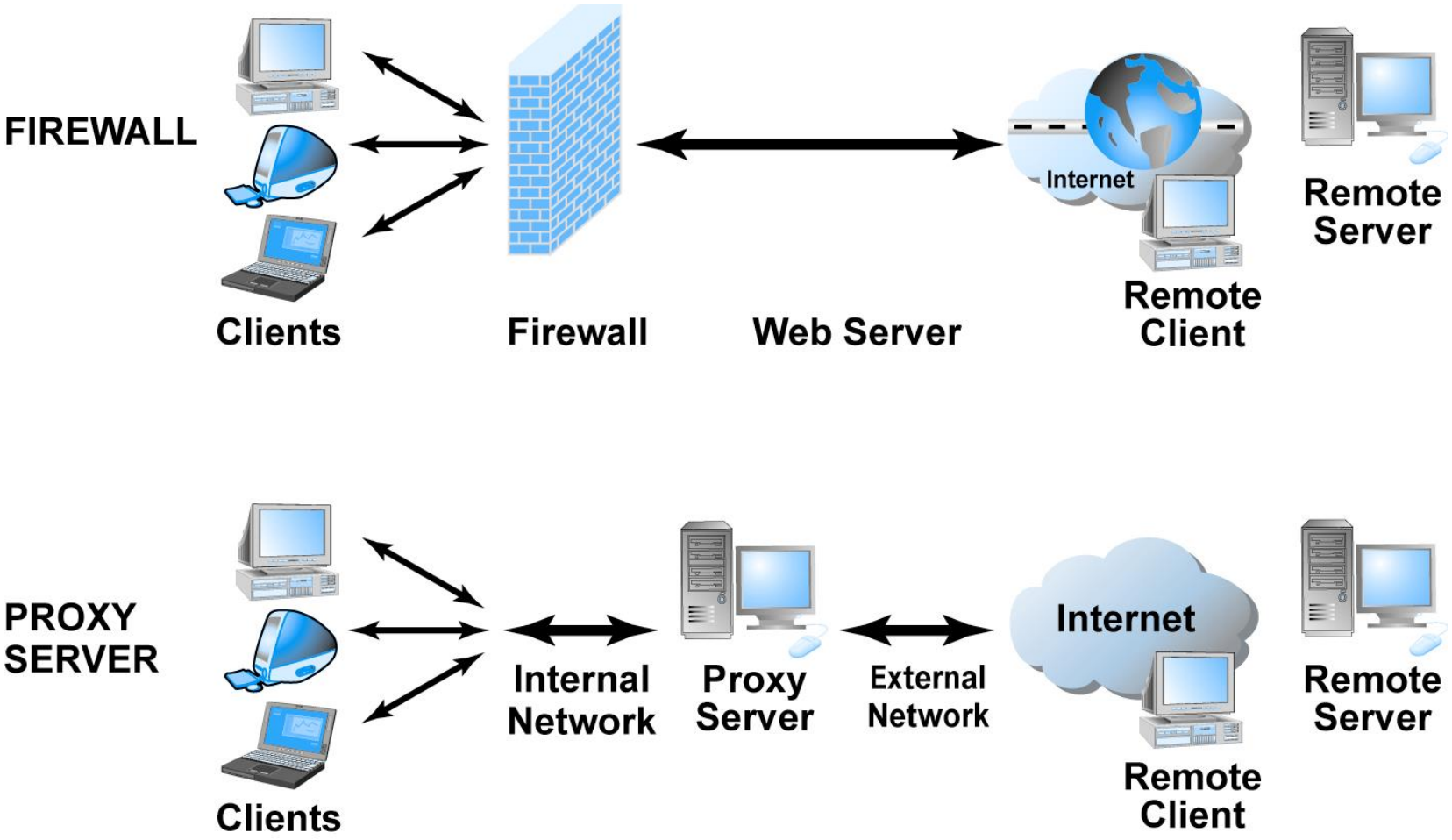


Figure 5.13, Page 301

Protecting Servers and Clients

- Operating system security enhancements
  - Upgrades, patches
- Anti-virus software
  - Easiest and least expensive way to prevent threats to system integrity
  - Requires daily updates

Management Policies, Business Procedures, and Public Laws

- U.S. firms and organizations spend 12% of IT budget on security hardware, software, services.
- Managing risk includes
  - Technology
  - Effective management policies
  - Public laws and active enforcement

A Security Plan: Management Policies

- Risk assessment
- Security policy
- Implementation plan
  - Security organization
  - Access controls
  - Authentication procedures, including biometrics
  - Authorization policies, authorization management systems
- Security audit

Developing an E-commerce Security Plan

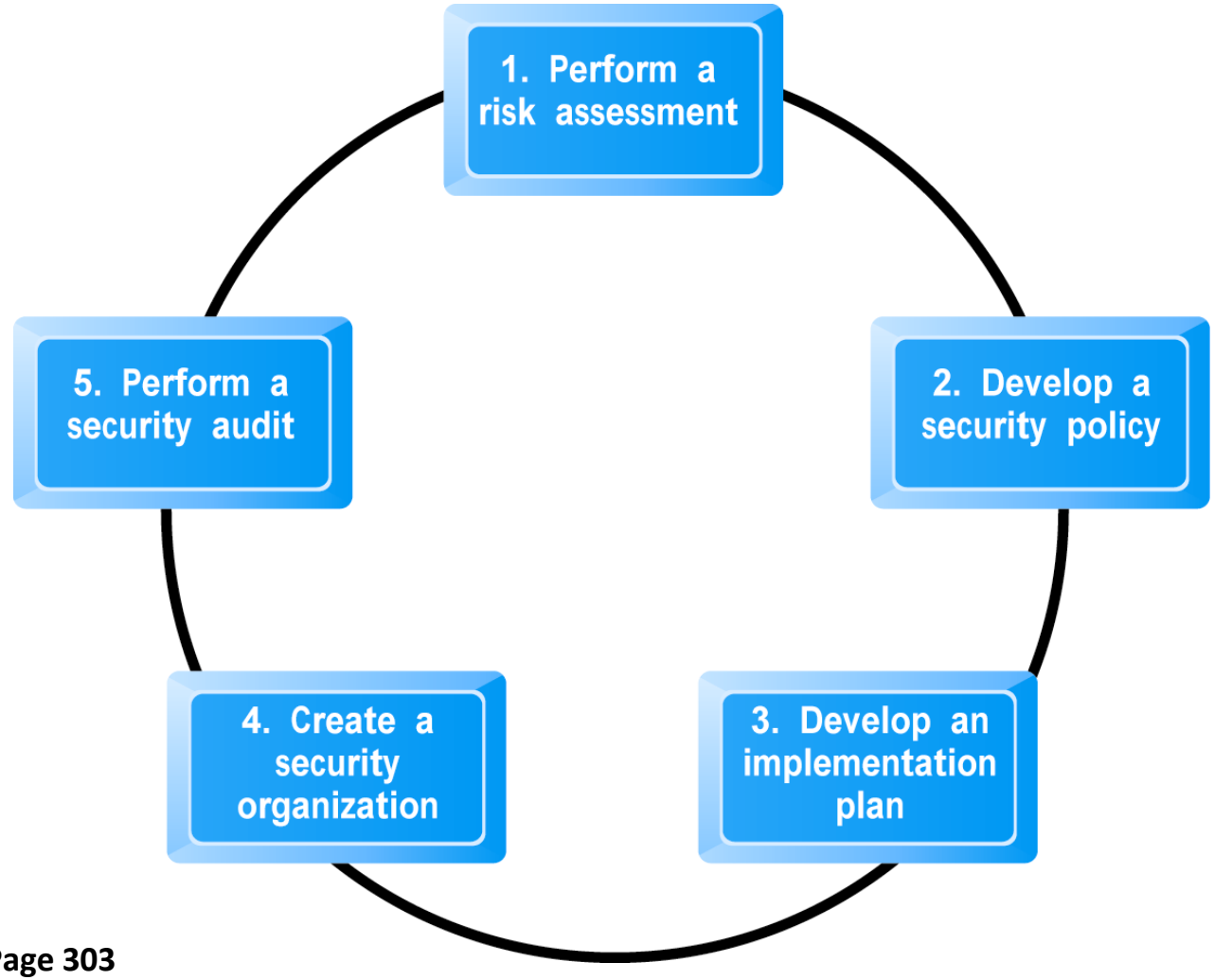


Figure 5.14, Page 303

Types of Payment Systems

- Cash
  - Most common form of payment in terms of number of transactions
  - Instantly convertible into other forms of value without intermediation
- Checking transfer
  - Second most common payment form in the United States in terms of number of transactions
- Credit card
  - Credit card associations
  - Issuing banks
  - Processing centers

E-commerce Payment Systems

- Credit cards
  - 55% of online payments
- Debit cards
  - 28% of online payments
- Limitations of online credit card payment
  - Security
  - Cost
  - Social equity

E-commerce Payment Systems

- Online stored value systems
  - Based on value stored in a consumer's bank, checking, or credit card account
  - PayPal, smart cards
- Digital accumulated balance payment
  - Users accumulate a debit balance for which they are billed at the end of the month
- Digital checking:
  - Extends functionality of existing checking accounts for use online

TABLE 5.6 DIMENSIONS OF PAYMENT SYSTEMS

DIMENSION	CASH	PERSONAL CHECK	CREDIT CARD	STORED VALUE (DEBIT CARD)	ACCUMULATING BALANCE
Instantly convertible without intermediation	yes	no	no	no	no
Low transaction cost for small transactions	yes	no	no	no	yes
Low transaction cost for large transactions	no	yes	yes	yes	yes
Low fixed costs for merchant	yes	yes	no	no	no
Refutable (able to be repudiated)	no	yes	yes	no (usually)	yes
Financial risk for consumer	yes	no	up to $50	limited	no
Financial risk for merchant	no	yes	yes	no	yes
Anonymous for consumer	yes	no	no	no	no
Anonymous for merchant	yes	no	no	no	no
Immediately respendable	yes	no	no	no	no
Security against unauthorized use	no	some	some	some	some
Tamper-resistant	yes	no	yes	yes	yes
Requires authentication	no	yes	yes	yes	yes
Special hardware required	no	no	yes—by merchant	yes—by merchant	yes—by merchant
Buyer keeps float	no	yes	yes	no	yes
Account required	no	yes	yes	yes	yes
Has immediate monetary value	yes	no	no	yes	no

Table 5.6, Page 312

Source: Adapted from MacKie-Mason and White, 1996.

How an Online Credit Transaction Works

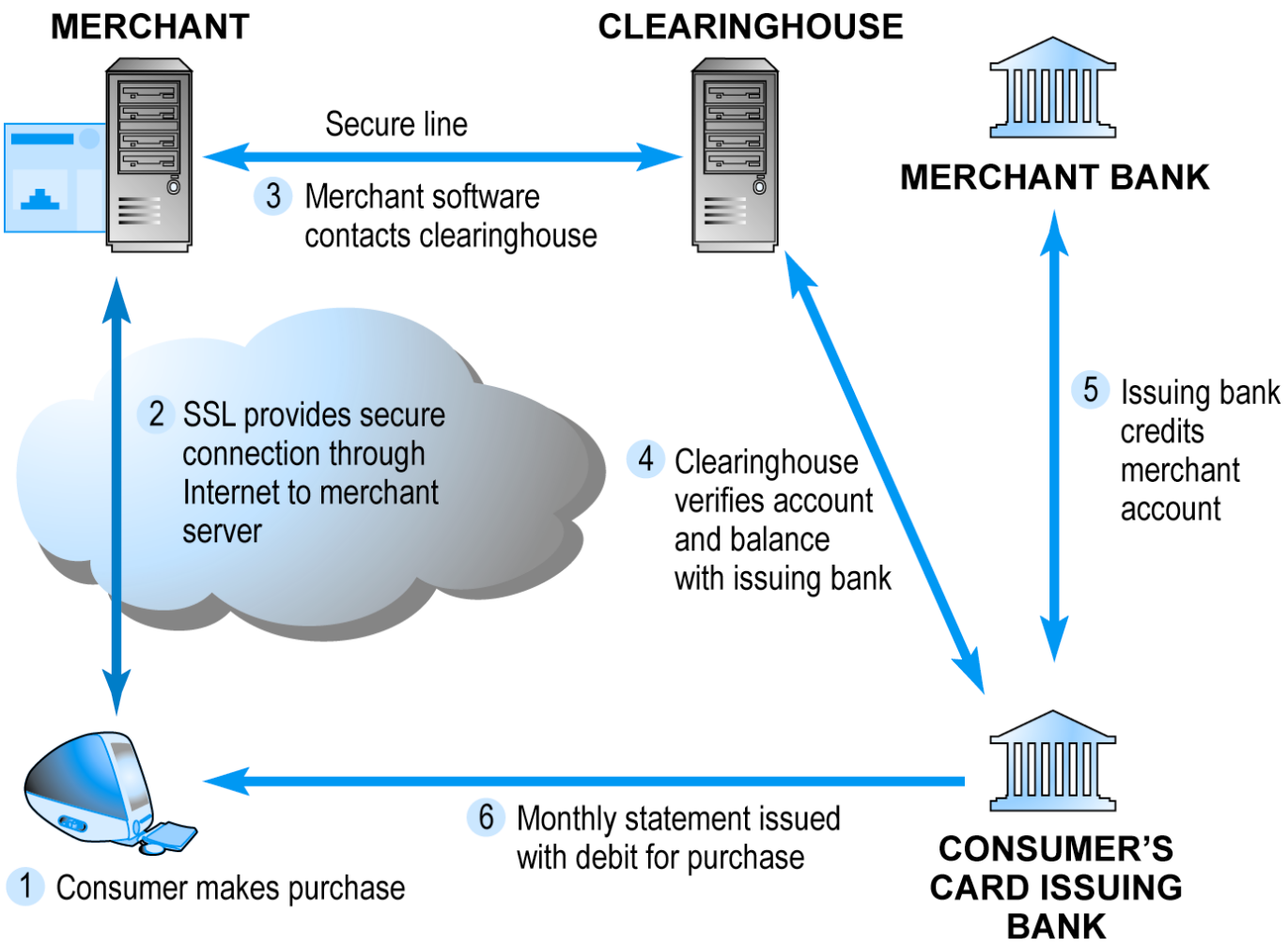


Figure 5.16, Page 315

E-commerce Payment Systems

- Digital wallets
  - Emulates functionality of wallet by authenticating consumer, storing and transferring value, and securing payment process from consumer to merchant
  - Early efforts to popularize failed
  - Newest effort: Google Checkout
- Digital cash
  - Value storage and exchange using tokens
  - Most early examples have disappeared; protocols and practices too complex

Wireless Payment Systems

- Use of mobile handsets as payment devices well-established in Europe, Japan, South Korea
- Japanese mobile payment systems
  - E-money (stored value)
  - Mobile debit cards
  - Mobile credit cards
- Not as well established yet in the United States
  - Majority of purchases are digital content for use on cell phone